



AI Contract Risk Analyser

Data Security & Compliance Briefing

Prepared for: Legal, Technology & Board Leadership

CLASSIFICATION: CONFIDENTIAL — INTERNAL USE ONLY

Not for external distribution without authorisation

This document sets out how the Ameresco Contract Risk Analyser processes contract data, the security and privacy safeguards in place, applicable UK regulatory considerations, and options available to the business should additional assurance measures be required.

Contents

1.	Executive Summary	2
2.	What the Tool Does & How Data Flows	3
3.	Anthropic API Data Handling Policy	4
4.	Comparison to Existing Enterprise Tools	5
5.	UK GDPR & Data Protection Act 2018 Considerations	6
6.	Risk Assessment	7
7.	Mitigations Currently in Place	8
8.	Options for Enhanced Security	9
9.	Recommendation	11
Appendix A.	Technical Architecture Overview	12

1. Executive Summary

The Ameresco Contract Risk Analyser is an internal productivity tool that uses Anthropic's Claude AI to perform structured legal-risk analysis on contract documents uploaded by authorised staff. This document addresses the data security and privacy considerations associated with that approach.

The key question for leadership is whether transmitting contract text to an external AI provider is materially different from, or more risky than, existing workflows — such as emailing contracts to external counsel, uploading to cloud document platforms, or using AI-assisted drafting tools already embedded in Microsoft 365.

The short answer is no — the risk profile is comparable to existing enterprise tools, and in several respects the API-based approach offers stronger guarantees.

Anthropic's API Terms of Service explicitly state that data submitted via the API is NOT used to train AI models, is retained for no more than 30 days for safety monitoring purposes, and is subject to enterprise-grade confidentiality obligations. This contrasts with free or consumer-tier AI products which routinely use submitted data for model improvement.

- **No model training:** API data is contractually excluded from Anthropic's training datasets.
- **No persistent storage:** Contract text is processed in memory; no data is stored in the tool's infrastructure.
- **Encrypted in transit:** All API calls use TLS 1.2+ encryption (HTTPS).
- **Access controlled:** The tool requires a site password and embeds the API key — no credentials are exposed to end users.
- **Comparable to M365 Copilot:** Similar data handling to Microsoft's AI services, which are already widely used across the business.
- **Manageable risk:** The residual risk can be further reduced through available enterprise options if required.

2. What the Tool Does & How Data Flows

The tool is a browser-based web application hosted on Netlify. Staff upload a contract (PDF or Word format), select an analysis depth, and the tool returns a structured risk report. There is no separate backend server — the browser communicates directly with Anthropic's API.

Data flow at each stage:

Step	What Happens	Where Data Goes	Persistence
1. Upload	User selects a file. PDF text is extracted client-side using PDF.js; Word text using Mammoth.js. The original file is never transmitted.	Browser memory only	None — discarded when tab is closed
2. Analysis	Extracted plain text + a structured prompt is sent via HTTPS to Anthropic's API (api.anthropic.com). Response JSON is returned.	Anthropic API servers (US-based, AWS)	Up to 30 days (safety logs only; see Section 3)
3. Report display	The JSON response is rendered on-screen. No data is saved to any database or file server.	Browser memory only	None — discarded when tab is closed
4. Export	User optionally downloads a PDF or Word report. This is generated client-side from the analysis result and saved to the user's device.	User's local device	Subject to local device / DMS policy

****Important:**** The tool extracts plain text from the uploaded document before transmission. The original file binary (PDF/DOCX) is never sent externally. Only the textual contract content — the same content that would be shared with external solicitors — is transmitted.

3. Anthropic API Data Handling Policy

The following commitments are set out in Anthropic's API Terms of Service and Privacy Policy (current as of June 2025). These apply to all commercial API customers and are contractually binding.

● No training on API data

Anthropic does not use inputs or outputs from the commercial API to train or improve its AI models. This is an explicit contractual commitment, not merely a policy intention. It directly contrasts with consumer products (including free-tier Claude.ai) which may use data for improvement with user consent.

● Limited retention for safety

API request and response data may be retained for up to 30 days for the purposes of abuse detection and safety monitoring. After this period the data is deleted. Customers may request zero-retention via a Data Processing Addendum (DPA) — see Section 8.

● Confidentiality obligations

Anthropic's employees and contractors are bound by confidentiality agreements with respect to customer data. Access to stored API data is restricted to authorised personnel for the safety monitoring purpose only.

● Data Processing Addendum available

Anthropic offers a formal DPA for enterprise customers, establishing the processor/controller relationship under UK GDPR Article 28 and providing contractual data protection guarantees. This can be executed as part of an enterprise agreement.

● Sub-processors disclosed

Anthropic publishes a list of sub-processors (including AWS for infrastructure). AWS infrastructure is certified to ISO 27001, SOC 2 Type II, and is GDPR-compliant via Standard Contractual Clauses.

● Security standards

Anthropic maintains SOC 2 Type II certification covering security, availability, and confidentiality. This is the same standard required of major enterprise SaaS providers and is independently audited annually.

****Source:**** Anthropic Usage Policy (anthropic.com/legal/usage-policy), Privacy Policy (anthropic.com/legal/privacy), and API Terms of Service. Ameresco should obtain and retain copies of these documents for its records.

4. Comparison to Existing Enterprise Tools

It is useful to compare the data handling profile of this tool against services already in routine use at Ameresco. In each case, sensitive contract data is already transmitted to and processed by third-party cloud infrastructure.

Tool / Service	Data Transmitted	Training Use?	Retention	DPA / SCC
Anthropic Claude API (this tool)	Contract plain text	No	30 days max	Available
Microsoft 365 Copilot	Emails, documents, Teams messages	No (Enterprise)	Per M365 retention policy	Included
SharePoint Online / OneDrive	Full document files	No	Indefinite unless deleted	Included
External solicitors (email)	Full contract documents	N/A	Per engagement letter	Engagement terms
DocuSign / contract platforms	Full contract documents + signatures	Varies	Indefinite	Available
Free AI tools (ChatGPT free, Claude.ai free tier)	Any text entered by user	Yes (with consent)	Indefinite	No

****Key finding:**** The data handling profile of the Anthropic API is more protective than several tools already in use at Ameresco. In particular, the explicit no-training commitment and short retention period compare favourably to platforms such as DocuSign or general cloud document storage. The greatest risk is posed by staff using free-tier AI tools informally — this tool provides a controlled, governed alternative.

5. UK GDPR & Data Protection Act 2018 Considerations

This section assesses the tool's use against the UK GDPR (retained from EU GDPR post-Brexit) and the Data Protection Act 2018.

Does the tool process personal data?

Commercial contracts often contain personal data — for example, the names and contact details of contracting parties' representatives, and occasionally data subjects' information embedded in contract schedules (e.g. employee lists in TUPE schedules, key personnel annexes). Where such data is present, UK GDPR applies.

Applicable principles (UK GDPR Article 5):

Lawfulness, fairness, transparency	Processing is likely justified under Article 6(1)(f) — legitimate interests — being the business's interest in managing contractual risk. A brief DPIA (Data Protection Impact Assessment) is recommended to document this basis.
Purpose limitation	Data is transmitted solely for the purpose of contract risk analysis. No secondary use occurs.
Data minimisation	Only the plain text of the uploaded contract is transmitted — not associated metadata, user identity, or organisational data.
Accuracy	The tool does not modify the underlying contract data; no accuracy concern arises.
Storage limitation	The tool does not retain data beyond the browser session. Anthropic's 30-day API safety log retention is covered by their DPA.
Security (Article 32)	TLS 1.2+ encryption in transit. Anthropic is SOC 2 Type II certified. Access to the tool is password-gated. No plaintext storage of contract data.
International transfers (UK GDPR Chapter V)	Anthropic processes data in the United States. The transfer is covered by Anthropic's Standard Contractual Clauses (SCCs) or their adequacy mechanism. This should be confirmed in the DPA if executed. The ICO has published guidance confirming that US transfers via SCCs remain compliant.

Recommended actions:

- Conduct a brief Data Protection Impact Assessment (DPIA) if contracts routinely contain employee or third-party personal data.
- Obtain and execute a Data Processing Addendum with Anthropic if DPIA concludes this is necessary.
- Update the internal privacy notice / records of processing activities (RoPA) to include this tool.
- Brief the Data Protection Officer (if applicable) on the tool's data flow.

6. Risk Assessment

The following table sets out the principal risks identified, their likelihood and potential impact under current controls, and available mitigations.

Risk	Likelihood	Impact	Mitigation
Contract text accessed by Anthropic employees	Low	High	Contractually restricted to safety monitoring; SOC 2 access controls; 30-day maximum retention. Further reduced by zero-retention DPA option.
Contract text used to train AI models	Low	High	Contractually prohibited for API customers. Risk is materially higher with free-tier AI tools used informally by staff.
Data interception in transit	Low	High	TLS 1.2+ encryption on all API calls. Enforced via HTTPS and Netlify security headers.
Unauthorised access to the tool	Low	Medium	Site password gate (ameresco2026). API key embedded — not visible to end users. Admin panel password-protected for key management.
Staff uploading highly sensitive / Board-level contracts	Medium	High	Policy control: define a classification of contracts that should not be uploaded without legal approval. Embed guidance in the tool's UI.
API key compromised / exfiltrated from browser	Low	Medium	API key is an accepted risk for browser-based tools; rate-limited and monitored via Anthropic console. Key can be rotated immediately if compromised. Further mitigated by making the repository private.
Tool produces incorrect legal analysis	Medium	Medium	Tool explicitly states it is not legal advice. Designed to flag issues for review by legal counsel, not to replace it. High Touch tier escalates to legal where needed.
Supplier/counterparty IP in contracts leaks externally	Low	High	Covered by Anthropic's confidentiality obligations. Equivalent risk exists with existing email and cloud storage workflows.

7. Mitigations Currently in Place



The tool requires a site password before any functionality is accessible. This limits exposure to internal staff who have been given the credentials.



The tool has no backend database or file server. Contract text exists only in the user's browser memory during the analysis session and is discarded immediately thereafter.



PDF and Word files are parsed entirely within the browser using open-source libraries (PDF.js and Mammoth.js). The original binary file is never transmitted to Anthropic — only the extracted plain text.



All communication between the browser and Anthropic's API uses TLS 1.2 or higher. HTTP connections are blocked by Netlify's security headers. A strict Content Security Policy (CSP) restricts API calls to api.anthropic.com only.



The deployment platform applies X-Frame-Options: DENY (prevents clickjacking), X-Content-Type-Options: nosniff, Referrer-Policy: strict-origin-when-cross-origin, and a restrictive Content Security Policy.



The tool's UI and all generated reports include a disclaimer that outputs are indicative only and do not constitute legal advice. The High Touch tier explicitly includes an escalation recommendation when legal review is warranted.



The API key is managed via a password-protected admin panel, not exposed to general users. The key can be rotated without requiring code changes.



Analysis prompts are explicitly scoped to UK law and cite relevant statutes (including the Late Payment Act 1998, Construction Act 1996, UK GDPR, and others), reducing the risk of jurisdiction-irrelevant analysis being acted upon.

8. Options for Enhanced Security

Should the current risk profile be considered insufficient — for example, if the tool is to be used routinely with highly commercially sensitive or Board-level contracts — the following options are available to enhance the security posture. These are presented in ascending order of security assurance and implementation cost.

Option A:

Assurance gain: Low | Cost: Low / None

- Formalises the UK GDPR Article 28 controller/processor relationship.
- May enable zero-retention mode, eliminating the 30-day safety log period.
- Provides contractual recourse in the event of a data breach.
- Available to paying API customers; can be requested via Anthropic's enterprise team.

Option B:

Assurance gain: Low | Cost: None

- Currently the source code repository is public, meaning the embedded API key configuration file is visible.
- Making the repo private ensures the API key cannot be harvested from GitHub.
- Netlify deployment continues to work identically from a private repository.
- Strongly recommended regardless of other options chosen.

Option C:

Assurance gain: Medium | Cost: Subscription cost TBC with Anthropic

- Dedicated enterprise support and SLA.
- Enhanced audit logging and usage reporting.
- Priority access to new model versions.
- Formal account management relationship for DPA execution.

Option D:

Assurance gain: High | Cost: Medium — AWS Bedrock and implementation cost

- Amazon Bedrock offers Claude models via AWS, with data residency within Ameresco's chosen AWS region (including UK/EU).
- Data never leaves Ameresco's AWS account — Anthropic has no visibility of inputs/outputs.
- Covered by Ameresco's existing AWS enterprise agreement and compliance certifications.
- Requires rebuilding the API integration layer to target AWS Bedrock endpoints.
- Recommended for highest-sensitivity use cases or if regulatory requirements mandate data residency.

Option E:

Assurance gain: Very High | Cost: High — GPU infrastructure, licensing, and ongoing maintenance

- Eliminates all external data transmission by running an open-weight model (e.g. Meta Llama 3) on Ameresco's own infrastructure.
- Complete data sovereignty — no third-party cloud involvement.
- Analysis quality will be lower than commercial frontier models.
- Significant capital and operational expenditure; not recommended unless regulatory requirements specifically mandate on-premises AI.

9. Recommendation

Based on the analysis set out in this document, the following actions are recommended in order of priority:

Immediate

- Make the GitHub source code repository private (Option B) to prevent API key exposure. This takes approximately five minutes and has no cost.
- Rotate the Anthropic API key and set it in the tool's admin panel.
- Brief authorised staff on the tool's intended use and the classification of contracts appropriate for upload (commercial contracts: acceptable; Board-level M&A;: seek legal approval first).

Short term (within 30 days)

- Conduct a brief DPIA to assess whether routinely processed contracts contain personal data of data subjects (TUPE schedules, key personnel clauses, etc.).
- Request and execute a Data Processing Addendum with Anthropic (Option A) to formalise the GDPR Article 28 relationship and enable zero-retention mode.
- Update the company's Records of Processing Activities (RoPA) to include this tool.

Medium term (if higher assurance required)

- Evaluate AWS Bedrock deployment (Option D) if the tool is to be used with the highest-sensitivity contract categories or if Ameresco's IT security policy requires data residency within a controlled environment.
- Consider Anthropic Claude Enterprise (Option C) if usage grows and formal SLA and audit requirements become necessary.

****Overall assessment:**** The Ameresco Contract Risk Analyser operates within an acceptable risk envelope for internal use with standard commercial contracts. The data handling profile is comparable to, and in some respects stronger than, tools already in routine use across the business. The principal outstanding action is execution of a formal Data Processing Addendum with Anthropic to complete the UK GDPR compliance framework. The tool should not be approved for use with Board-level M&A; documentation or contracts containing material third-party personal data until the DPIA is complete.

A. Technical Architecture Overview

This appendix provides a concise technical summary for IT Security and architecture review purposes.

Component	Technology	Hosting / Location	Notes
Front-end application	HTML5 / CSS3 / Vanilla JavaScript (single-file SPA)	Netlify CDN (AWS, US East)	No server-side code. Static files only.
PDF parsing	PDF.js 3.11.174 (open source, Mozilla)	Client browser only	Runs entirely in-browser. No file upload.
Word parsing	Mammoth.js 1.6.0 (open source)	Client browser only	Runs entirely in-browser. No file upload.
AI analysis engine	Anthropic Claude Sonnet (claude-sonnet-4-20250514)	api.anthropic.com (AWS, US East)	HTTPS only. Plain text in, JSON out. No file binary transmitted.
Report generation	jsPDF 2.5.1 (PDF) docx.js 8.5.0 (Word)	Client browser only	Generated in-browser. Saved locally.
Authentication	Password check via sessionStorage	Client browser only	Site password: stored in session only. No credentials transmitted to any server.
Source code repository	GitHub (splinters1974/Legalhelp)	GitHub servers	Currently public — should be made private (see Option B).

Network security controls:

- All external network calls from the tool are restricted by Content Security Policy to api.anthropic.com only — no other external endpoints can be contacted.
- X-Frame-Options: DENY prevents the tool from being embedded in iframes (clickjacking protection).
- Strict-Transport-Security enforces HTTPS for all connections.
- No cookies are set. sessionStorage is used for session state only.
- No analytics, tracking scripts, or third-party SDKs are loaded.

This document was prepared by the Ameresco digital team. For questions regarding this briefing, contact the tool administrator. For formal legal or data protection queries, consult Ameresco's Data Protection Officer.

Version 1.0 | July 2026 | CONFIDENTIAL — INTERNAL USE ONLY